COLORADO
Information Security
Governor's Office of Information Technology

TS-INF-015: Information Technology Multifactor Authentication (MFA)

Document ID	TS-INF-015
Title	Information Technology Multifactor Authentication (MFA)
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	Employees of OIT, agencies supported by OIT, and vendors contracted by OIT and its stakeholders; applies to any OIT unit or contracted entity providing these services to customers.
Instrument Type	Standard
Version	2.0
Effective Date	04/24/2026
Last Updated	05/14/2026

1. Purpose

The purpose of an Enterprise Two-factor Authentication (2FA) Standard is to enable strong authentication of users with access to sensitive information and information systems resources, or who have a privileged level of support access, while ensuring ease of use and user adoption. Adoption of this standard will reduce unauthorized access and demonstrate compliance with federal and industry mandates, and will enable solicitation, assessment, and selection of the 2FA solution(s) that implement these requirements.

2. Scope

These standards apply to and shall be used by employees of OIT, agencies supported by OIT, and vendors contracted by OIT and its stakeholders, as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient. This applies to any OIT unit or contracted entity providing these services to customers.

3. Defined Terms

- MFA: A security process requiring 2+ credentials — such as a password, phone code, or fingerprint — to verify identity, protecting against unauthorized access even if one factor is compromised.
- Approved Authentication Methods: Methods approved by security to be utilized for MFA.
- PING: OIT standard authentication tool.

- SAML: An open-standard, XML-based protocol for exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP).
- OAuth: An open-standard protocol for token-based authorization that allows users to grant third-party applications limited access to their resources without sharing their passwords.
- TOTP: A secure, temporary 6-8 digit code generated by an authenticator app that changes every 30-60 seconds.
- OpenID Connect (OIDC): A modern, open-standard authentication protocol built on top of the OAuth 2.0 framework.
- Privileged Account: An account with elevated permissions beyond a standard user, including administrative access to systems, databases, or network configurations.

4. Policy

Authentication must be derived from at least two of the following three categories:

- Knowledge: Something you know, such as a PIN or password.
- Possession: Something you have, such as a FIDO2 security key, smartphone, or TOTP app.
- Inherence: Something you are, such as fingerprint or facial recognition.

Authentication must meet requirements set by TS-CISO-001 Authentication & Account Management Standard v. 2026.

5. IT Security Planning

Enterprise PingID 2FA SSP.

6. Managing and Mitigating IT Risk

Business System Owner

The Business System Owner has sufficient knowledge of the system to provide additional information or points of contact regarding the security plan and the system, as needed, and is the decision-making authority for the budgetary and operational function of the system or solution.

System Subject Matter Expert/Administrator

The Subject Matter Expert (SME) is the individual responsible for the overall business management and administration of the system, involved in all operational discussions for the system (user access control, documentation, applications, data, design, and disaster recovery requirements), and is the primary business contact for all security events affecting the system.

Authorizing Security Official

The Colorado Chief Information Security Officer (CISO), or delegate, after review of each System Security Plan (SSP), is the individual responsible for sponsoring and approving the operation, or denying operation, of state computing systems and solutions for the State of Colorado.

7. Approved Authentication Methods

Authentication methods explicitly sanctioned by the State CISO or delegate for use in satisfying MFA requirements are detailed below.

Priority	Method	Description	Security Level
High	FIDO2 / WebAuthn	Physical hardware keys (YubiKey) or platform authenticators (TouchID/Windows Hello).	Phishing-resistant; cryptographically bound.
Medium	TOTP (RFC 6238)	Time-based one-time passwords generated via apps (Google Authenticator, Okta Verify).	Resilient against basic reuse; vulnerable to proxy phishing.
Medium	Push Notification	Cryptographic “Approve/Deny” prompts on a registered mobile device.	High UX; requires “Number Matching” to prevent MFA fatigue attacks.
Low	SMS	Delivery of a code via cellular network or SMTP.	Discouraged. Vulnerable to SIM swapping and account hijacking.

8. Security Awareness Training and Education

The following resources support security awareness training and education:

- Two-factor User Guide
- Tech Kit

9. Compliance

Failure of users to comply with this standard may result in, as applicable:

- Loss of federal grant funding, fines, and penalties.
- Agency-level sanctions regarding state IT resources: restriction, deactivation, or suspension of the user's account, project, or system, or termination of employment.
- Termination of contract or assignment for temporary workers, interns, volunteers, contractors, or vendors who violate this policy.

Non-consolidated agencies must have appropriate policies and procedures to ensure compliance with this policy and all other Colorado Information Security Policies.

10. Exceptions

Any exceptions to this policy must be documented, justified, and approved in advance of implementation. Requestors must submit a Secure Configuration Exception Request.

11. References

- TS-CISO-001 Authentication & Account Management Standard v. 2026
- Enterprise PingID 2FA SSP